

PLANTILLA PARA EPICAS(HU)

ID:	EP-001
Nombre:	Gestión de Autenticación, Usuarios y Seguridad
Objetivo de Negocio:	Garantizar un acceso seguro, controlado y auditado a la plataforma Celuaccel mediante autenticación por tokens (JWT), control de sesiones por inactividad y gestión centralizada de roles y perfiles
Descripción:	Módulo encargado del ciclo de vida de la sesión y perfil del usuario: inicio de sesión, registro, recuperación de contraseña, gestión de datos personales, control de inactividad a los 15 minutos, y asignación de roles y tipos de documentos.
Funcionalidades Incluidas:	Inicio de Sesión y Autenticación: Autenticación segura de usuarios utilizando tokens JWT. Registro de Usuarios: Creación de nuevas cuentas con captura de datos personales y selección de tipo de documento. Recuperación de contraseña: Flujo seguro para el restablecimiento de credenciales de acceso. Gestión de Sesiones: Cierre de sesión automático por inactividad tras transcurrir 15 minutos. Gestión de Perfil y Roles: Administración de la información del perfil de usuario y asignación centralizada de roles/permisos
Historias Asociadas:	RF-HU-001: CRUD Perfil de Usuario RF-HU-002: Registro y Autenticación de Usuarios (JWT) RF-HU-003: Administrar Roles RF-HU-004: CRUD Mensajes RF-HU-005: Recuperación de Contraseña RF-HU-006: Control de Inactividad y Sesión

Criterios Generales:	Seguridad Token: Todos los endpoints protegidos del backend deben validar la firma del token JWT en cada petición. Seguridad de Claves: Las contraseñas deben almacenarse encriptadas (hashing con algoritmos seguros como BCrypt). Validaciones de Inactividad: El cliente (frontend) y backend deben sincronizar el temporizador de 15 minutos para invalidar la sesión sin actividad. Integridad de Datos: No se permite el registro de correos ni documentos de identidad duplicados.
Riesgos:	-Vulnerabilidad en el almacenamiento de Tokens -Fuerza Bruta en el Login. -Pérdida de Estado por Inactividad

Ejemplo:

ID:	EP-002
Nombre:	Gestión de Empleados
Objetivo de Negocio:	Permitir administrar el personal de la repostería garantizando el control de acceso, la seguridad y la operación del negocio.
Descripción:	Como administrador de la repostería, Quiero gestionar los empleados, Para controlar la información del personal y las operaciones del sistema.
Funcionalidades Incluidas:	- Registrar empleados. - Consultar empleados. - Actualizar empleados.

	- Desactivar empleados.
Historias Asociadas:	- HU-002.1 Registrar empleado - HU-002.2 Consultar empleados - HU-002.3 Actualizar empleado - HU-002.4 Desactivar empleado
Criterios Generales:	- Solo los administradores pueden gestionar empleados. - Toda operación debe auditarse. - Los empleados inactivos no pueden autenticarse.
Riesgos:	● Escalamiento de privilegios. ● Duplicidad de empleados. ● Pérdida de trazabilidad.

PLANTILLA HISTORIA DE USUARIO (HU)

ID:	RH-HU 001
Épica:	EP-001
Nombre:	CRUD Perfil de Usuario
Prioridad:	Alta
Sprint:	1
Story Points:	8

Historia:	Como: Todos los Roles Quiero: CRUD Perfil de Usuario Para: Tener acceso al sistema mediante la opción de crear, ingresar, actualizar y eliminar perfiles de Usuario según el rol que se esté usando
Descripción funcional:	El sistema debe permitir a los usuarios según su rol asignado (Administrador, Técnico, Cliente) realizar las operaciones de creación, lectura, actualización y eliminación (CRUD) de sus perfiles de usuario. Incluye la gestión de sus datos personales, credenciales de acceso y permisos dentro de la plataforma CeluAcce
Reglas de negocio:	-El correo electrónico y el número de documento deben ser únicos en el sistema. -La contraseña debe cumplir con políticas de seguridad (mínimo 8 caracteres, al menos una letra mayúscula, un número y un carácter especial). -Un usuario con rol Cliente o Técnico no puede cambiar su propio rol; la asignación de roles es exclusiva del Administrador. -La eliminación de un perfil debe ser una eliminación lógica (desactivar estado/soft delete) para conservar la trazabilidad de historiales técnicos e inventario.

Datos requeridos:	<table><tr><th>Campos</th><th>Obligatorio</th><th>Validación</th></tr><tr><td>Número de Identificación</td><td>SI</td><td>Varchar de tamaño 50</td></tr><tr><td>Tipo de Identificación</td><td>SI</td><td>tinyint(3)</td></tr><tr><td>Nombre</td><td>SI</td><td>Varchar tamaño 150</td></tr><tr><td>Fecha de Nacimiento</td><td>SI</td><td>Date</td></tr><tr><td>Dirección</td><td>SI</td><td>Varchar tamaño 150</td></tr><tr><td>Telefono</td><td>SI</td><td>Varchar tamaño 20</td></tr><tr><td>Correo Electrónico</td><td>SI</td><td>Taynint tamaño 3</td></tr><tr><td>Contraseña</td><td>SI</td><td>Varchar tamaño 100</td></tr></table>	Campos	Obligatorio	Validación	Número de Identificación	SI	Varchar de tamaño 50	Tipo de Identificación	SI	tinyint(3)	Nombre	SI	Varchar tamaño 150	Fecha de Nacimiento	SI	Date	Dirección	SI	Varchar tamaño 150	Telefono	SI	Varchar tamaño 20	Correo Electrónico	SI	Taynint tamaño 3	Contraseña	SI	Varchar tamaño 100
	Campos	Obligatorio	Validación																									
	Número de Identificación	SI	Varchar de tamaño 50																									
	Tipo de Identificación	SI	tinyint(3)																									
	Nombre	SI	Varchar tamaño 150																									
	Fecha de Nacimiento	SI	Date																									
	Dirección	SI	Varchar tamaño 150																									
	Telefono	SI	Varchar tamaño 20																									
	Correo Electrónico	SI	Taynint tamaño 3																									
	Contraseña	SI	Varchar tamaño 100																									
Criterios de aceptación (BDD):	El sistema debe permitir que Todos los roles puedan crear, acceder, actualizar y eliminar perfiles usando llaves como contraseñas																											
Dependencias:	EP-001(Gestión de Autenticación / Base de datos de usuarios creada). Configuración de la base de datos relacional y servidor Backend.																											
Mockups:																												
Definition of Done:	● Backend con endpoints REST funcionales (POST, GET, PUT, DELETE). ● Validaciones de entrada implementadas tanto en el Frontend como en el Backend. ● Contraseñas encriptadas correctamente en la base de datos. ● Pruebas unitarias de controladores y servicios																											

	aprobadas. • Interfaz de usuario adaptada a la línea gráfica e integrada con las APIs.
Casos de prueba asociados:	N/A
Riesgos:	Inyección SQL : Riesgo de vulnerabilidades si las entradas del formulario no se sanitizan adecuadamente. Conflicto de Roles: Riesgo de escalado de privilegios si no se validan los permisos del token JWT en las rutas del backend.
Trazabilidad:	Épica: EP-011 - Gestión de Autenticación Módulo: Autenticación y Control de Usuarios Requisito del Sistema: FR-001 - Gestión de Perfiles de Usuario

Nota:

BDD significa: Behavior Driven Development (Desarrollo Guiado por el Comportamiento).

Es una metodología que busca que **negocio, desarrollo y QA hablen el mismo idioma**.

En lugar de escribir requisitos ambiguos, se describen los comportamientos esperados del sistema mediante escenarios.

Por eso los criterios de aceptación se redactan así:

Dado (Given)

Cuando (When)

Entonces (Then)

O simplemente colocando:

Given

When

Then

Ejemplo de una historia de usuario:

ID:	HU-002.1
Épica:	EP-002 Gestión de Empleados
Nombre:	Registrar Empleado
Prioridad:	Alta.
Sprint:	Sprint 2. (Esto depende de la planificación.)
Story Points:	5 SP. <i>(Para aprendizaje normalmente se utilizan 3, 5 u 8.)</i>
Historia:	Como: Administrador Quiero: Registrar empleados. Para: Gestionar el personal de la repostería y asignarles acceso al sistema.

Descripción funcional:	El sistema deberá permitir registrar nuevos empleados asignándoles un rol y generando las credenciales necesarias para su autenticación.		
Reglas de negocio:	RN-001 Solo el administrador puede registrar empleados.		
	RN-002 El documento debe ser único.		
	RN-003 El correo electrónico debe ser único.		
	RN-004 Todo empleado deberá tener un rol. Roles permitidos: - Vendedor - Repostero		
	RN-005 Se deberá generar una contraseña temporal.		
	RN-006 El empleado deberá cambiar la contraseña en el primer inicio de sesión.		
	RN-007 Toda operación deberá registrarse en auditoría.		
Datos requeridos:			
	Campo	Obligatorio	validacion
	Documento	si	numerico , longitud de 10 digitos
	Nombres	Si	Texto 100caracteres
	Apellidos	Si	Texto 100caracteres
	Teléfono	Si	Numerico maximo 12 digitos
	Correo	si	Validación de correo y único
	Rol	si	Viene de la BD. solo vendedor/repostero
	Estado	Si	Por defecto cuando se

	<table><tr><td></td><td></td><td>registra queda activo.</td></tr></table>			registra queda activo.
		registra queda activo.		
Criterios de aceptación (BDD):	CA-001 Registro exitoso Dado que el administrador ha iniciado sesión, Cuando ingrese información válida y presione Guardar, Entonces el sistema deberá registrar el empleado. CA-002 Documento duplicado Dado que el documento ya existe, Cuando se intente registrar un nuevo empleado, Entonces el sistema deberá impedir el registro. CA-003 Correo duplicado Dado que el correo ya existe, Cuando se intente registrar el empleado, Entonces el sistema deberá impedir el registro. CA-004 Campos obligatorios Dado que existen campos obligatorios vacíos, Cuando el administrador intente guardar, Entonces el sistema deberá mostrar las validaciones correspondientes. CA-005 Permisos Dado que el usuario no posee rol Administrador, Cuando intente acceder al módulo, Entonces el sistema deberá denegar el acceso. CA-006 Auditoría Dado que se registra un empleado, Entonces el sistema deberá almacenar la operación en auditoría.			
Dependencias:	RF-001 Inicio de Sesión. RF-003 Gestión de Roles. Módulo de Auditoría.			
Mockups:	Aquí normalmente se coloca: ● Enlace de Figma. ● Imagen del formulario. ● Wireframe. Ejemplo: MOCK-002 Formulario Registrar Empleado			

Definition of Done:	La historia se considerará terminada cuando: - El código se encuentra desarrollado. - Las validaciones funcionan correctamente. - Los casos de prueba sean exitosos. - La auditoría funciona. - La documentación se encuentra actualizada. - No existen defectos críticos.												
Casos de prueba asociados:	- CP-001 Registro exitoso - CP-002 Documento duplicado - CP-003 Correo duplicado - CP-004 Campos vacíos - CP-005 Usuario sin permisos - CP-006 Validar auditoría												
Riesgos:	Acceso no autorizado: Alto Duplicidad de información: Alto Error en asignación de roles: Alto Pérdida de auditoría: Medio												
Trazabilidad:	<table> <tr> <th>Artefacto</th><th>Relación</th></tr> <tr> <td>Épica</td><td>EP-002</td></tr> <tr> <td>RF</td><td>RF-002.1</td></tr> <tr> <td>Caso de Uso</td><td>CU-002.1</td></tr> <tr> <td>Casos de prueba</td><td>CP-001 al CP-006</td></tr> <tr> <td>RNF</td><td>RNF-001, RNF-003</td></tr> </table>	Artefacto	Relación	Épica	EP-002	RF	RF-002.1	Caso de Uso	CU-002.1	Casos de prueba	CP-001 al CP-006	RNF	RNF-001, RNF-003
Artefacto	Relación												
Épica	EP-002												
RF	RF-002.1												
Caso de Uso	CU-002.1												
Casos de prueba	CP-001 al CP-006												
RNF	RNF-001, RNF-003												

